

Threat Modeling & Risk in Practice

The capstone: assess one system end-to-end

Choose a system YOU own/handle (a home server, a tiny web app, your lab) and run the full risk process.

Workflow

1. Inventory: assets, data, flows, tech (draw it)
2. Threat model: STRIDE every element, note top risks
3. Assess: L/I per risk (register), target each mitigation
4. BIA-lite: what's the downtime/data-loss cost?
5. Decide: accept/mitigate/transfer each (document!)
6. Re-calc residual: the register after controls
7. Report: 1-page exec summary

Common trap: analysis paralysis

Assess at the level the decision needs (no 200-line table for a home router)

Iterate: first pass coarse, then drill where score is high

Document *assumptions* (the register without assumptions is voodoo)

Tools for play

OWASP Threat Dragon (DFD + note)

A simple risk register – spreadsheet is fine

For formal clients: FAIR + vendor questionnaires

The deliverable shape

Executive summary: top 3 risks, ALE/financial if quantifiable, one ask
Register: full list w/ scores, owners, decisions, review dates

Assumptions: explicitly stated limits

The assessor's best output isn't the perfect model – it's the *decision it enabled*. Run the loop on one real system and you've earned the badge.

[← Cyber Insurance & Third-Part...](#)

Module complete ✓